



SOLUCIÓN DEL EJERCICIO: CASO MEDICITAS

ASEGURAMIENTO DE LA CALIDAD DEL SOFTWARE
Julio 2026

Tabla de contenido

- | | |
|--|---|
| 01. <u>El caso: sistema MediCitas</u> | 04. <u>Lista de control de revision tecnica</u> |
| 02. <u>Hallazgos de seguridad</u> | 05. <u>Plan y hallazgos de auditoria</u> |
| 03. <u>Matriz de verificacion y validacion</u> | 06. <u>ISO 25010, metricas y conclusiones</u> |

EL CASO: SISTEMA MEDICITAS (v3.2)

IPS Salud Especial, red de 12 clínicas ambulatorias en Bogotá y municipios cercanos

Contexto organizacional

- Equipo Scrum de 8 personas: 1 PO, 1 SM, 4 desarrolladores y 2 dedicados parcialmente a pruebas; sin área de QA independiente.
- Fecha de liberación fijada contractualmente en 3 semanas, con el alcance de la v3.2 ya congelado (change freeze).
- Presión comercial por lanzar telemedicina antes que una IPS competidora.
- Infraestructura híbrida: servidores propios para datos clínicos y AWS para telemedicina.

Actores involucrados

- Pacientes (app móvil / portal web) y personal médico y administrativo.
- Administrador de TI / DBA y oficial de protección de datos.
- Equipo de desarrollo Scrum.
- Proveedores externos: pasarela de pagos PayGateCol y API de WhatsApp Business.

Versión 3.2 en preparación: nuevo módulo de telemedicina (videoconsulta) + rediseño de autenticación SSO. Se libera en 3 semanas, con el alcance ya congelado y presión comercial por ser primeros en telemedicina.

FUNCIONALIDADES CRITICAS Y RESTRICCIONES

Ocho funcionalidades críticas y ocho restricciones tecnico-regulatorias delimitan el alcance

Funcionalidades críticas

- Autenticación y gestión de sesiones (incluye SSO).
- Agendamiento y cancelación de citas médicas.
- Consulta y edición de historias clínicas electrónicas (HCE).
- Emisión de órdenes médicas y recetas electrónicas.
- Facturación electrónica integrada con la DIAN.
- Módulo de telemedicina (videoconsulta), en desarrollo.
- Notificaciones y recordatorios por SMS/WhatsApp.
- Reportes gerenciales e indicadores clínicos.

Restricciones técnicas y regulatorias

- Ley 1581/2012 y Decreto 1377/2013 — protección de datos personales.
- Resolución 1995/1999 — custodia y seguridad de la historia clínica.
- Resoluciones 2654/2019 y 3100/2019 — telesalud y habilitación de telemedicina.
- PCI-DSS — datos de tarjetas en el módulo de pagos.
- Disponibilidad mínima: 99.5% en horario de atención (7 a.m.–9 p.m.).
- Integración batch nocturna con el legado AS/400.
- Infraestructura híbrida on-premise (datos clínicos) + AWS (telemedicina).
- Fecha de liberación y alcance ya congelados contractualmente.

HALLAZGOS DE SEGURIDAD IDENTIFICADOS

Cinco hallazgos con su evidencia en la bitacora de incidencias y su impacto sobre el sistema

N°	Hallazgo	Evidencia	Impacto
1	Control de acceso roto (IDOR): un médico accedió a HCE de pacientes no asignados alterando el ID en la URL.	INC-101	Violación de confidencialidad clínica; incumple Res. 1995/1999 y Ley 1581/2012; riesgo legal y reputacional alto.
2	Cuenta administrativa “admin_ti” compartida entre 4 personas; contraseñas sin expiración.	INC-102	Pérdida de trazabilidad y no repudio; mayor superficie de ataque sobre cuentas privilegiadas.
3	Canal de videoconsulta transmitido sin cifrar (config. de pruebas pasó a producción sin control de cambios).	INC-103 / CR-202	Expone datos de salud en tránsito; incumple RF-060 y Res. 2654/2019; evidencia falla de control de cambios.
4	Logs de la pasarela de pagos muestran el número completo de la tarjeta sin enmascarar.	INC-104	Incumplimiento directo de PCI-DSS; riesgo de fraude financiero y sanción contractual con PayGateCol.
5	No se registran los accesos de lectura a la historia clínica, solo las escrituras.	INC-105 / RF-045	Impide detectar accesos indebidos (como INC-101); incumple RF-045 y la trazabilidad exigida por Res. 1995/1999.

MATRIZ DE VERIFICACION Y VALIDACION - PARTE 1

Solucion de la plantilla de la seccion 3 del archivo de apoyo (filas 1 a 5)

ID	Requisito / funcionalidad	Tipo	Técnica y responsable	Criterio de aceptación
Ej.	RF-014 — Autenticación 2FA	Verificación	Revisión de código + inspección de configuración — Líder técnico	2FA disponible y exigible para roles críticos
1	RF-022 — Cifrado de HCE en reposo (AES-256)	Verificación	Revisión de configuración de cifrado + inspección de BD — Administrador de TI/DBA	Todos los campos de datos clínicos cifrados con AES-256
2	RF-031 — Rendimiento de agendamiento bajo carga	Validación	Prueba de carga con 100 usuarios concurrentes — Equipo de pruebas	Tiempo de respuesta ≤ 2 s en el percentil 95
3	RF-045 — Trazabilidad de accesos a HCE (lectura y escritura)	Verificación	Inspección de logs + revisión de código de auditoría — Líder técnico	Todo acceso de lectura y escritura queda registrado de forma inmutable
4	RF-052 — Cumplimiento PCI-DSS en pagos	Verificación	Auditoría de cumplimiento PCI-DSS — Oficial de protección de datos / auditor externo	Cero campos de PAN completo en logs o base de datos

MATRIZ DE VERIFICACION Y VALIDACION - PARTE 2



Continuacion de la matriz de verificacion y validacion (filas 6 a 9)

ID	Requisito / funcionalidad	Tipo	Técnica y responsable	Criterio de aceptación
5	RF-060 — Cifrado extremo a extremo del canal de video	Verificación	Revisión de configuración TLS/SRTP del servidor de videoconferencia — Administrador de TI	Canal siempre servido sobre HTTPS/SRTP, nunca HTTP
6	CR-201 — Autenticación SSO	Validación	Prueba de aceptación con personal médico y administrativo — Product Owner + usuarios piloto	Inicio de sesión único funcional en los 3 roles, sin bloqueos
7	Control de acceso por rol a la HCE (INC-101)	Verificación	Inspección de código + pentesting dirigido (IDOR) — Equipo de pruebas de seguridad	Ningún usuario accede a historias de pacientes no asignados
8	Integración batch nocturno con AS/400 (INC-106)	Validación	Prueba de integración + monitoreo de alertas — Administrador de TI/DBA	Cero fallos no alertados en 4 semanas de observación
9	Módulo de telemedicina — experiencia de usuario	Validación	Prueba piloto con pacientes y personal médico — Product Owner	Videoconsulta estable y cifrada; satisfacción ≥ 90% en encuesta piloto

LISTA DE CONTROL DE REVISION TECNICA - PARTE 1

Solucion de la seccion 4 del archivo de apoyo (items 1 a 7)

N°	Ítem de revisión	Cumple	Observaciones / evidencia
1	El código fuente cumple los estándares de codificación definidos por el equipo.	N.A.	El escenario no aporta evidencia sobre estándares de codificación del equipo.
2	Existe trazabilidad entre los requisitos y los casos de prueba.	No	RF-031 y RF-060 no cuentan con casos de prueba ejecutados (ver 2.4).
3	Todos los cambios fueron documentados y aprobados antes de su despliegue.	No	CR-202 y CR-205 se desplegaron sin revisión registrada (ver 2.3).
4	Los mecanismos de autenticación y autorización protegen los recursos críticos.	No	INC-101 evidencia IDOR sobre HCE; 2FA es opcional (RF-014).
5	La información sensible se almacena y transmite cifrada.	No	RF-022 pendiente de verificación; INC-103: video sin cifrar.
6	Existen registros de auditoría para accesos y modificaciones a información crítica.	No	RF-045: solo se registran escrituras, no lecturas (INC-105).
7	Se ejecutaron pruebas de seguridad (pentesting) antes de la liberación.	No	Pentesting de HCE “No ejecutada”, sin tiempo asignado (ver 2.4).

LISTA DE CONTROL DE REVISION TECNICA - PARTE 2

Continuacion del checklist de revision tecnica (items 8 a 14)

N°	Ítem de revisión	Cumple	Observaciones / evidencia
8	Se ejecutaron pruebas de carga/rendimiento sobre los módulos críticos.	No	RF-031 no probado bajo carga; telemedicina “No ejecutada” (ver 2.4).
9	El manejo de datos personales cumple con la Ley 1581 de 2012.	No	INC-101, INC-102 y RF-022 pendiente evidencian brechas de protección de datos.
10	El manejo de la historia clínica cumple con la Resolución 1995 de 1999.	No	Falta de registro de lecturas (INC-105) y acceso indebido (INC-101).
11	El módulo de telemedicina cumple con la Resolución 2654 de 2019.	No	Canal sin cifrar (INC-103) incumple condiciones de seguridad de telesalud.
12	Existen alertas automáticas ante fallos de procesos críticos.	No	INC-106: el batch de facturación falló 3 veces sin alerta.
13	La documentación técnica y de usuario está actualizada para la versión a liberar.	N.A.	Sin evidencia en el escenario; verificar antes de la liberación.
14	Los riesgos técnicos y regulatorios identificados fueron mitigados antes de la liberación.	No	Persisten 5 hallazgos de seguridad abiertos y pruebas críticas sin ejecutar a 3 semanas del release.

PLAN DE AUDITORIA: DATOS GENERALES



Solucion de la seccion 5.1 del archivo de apoyo

Objetivo de la auditoría	Evaluar el cumplimiento de MediCitas v3.2 con los requisitos de seguridad, protección de datos y regulación de telesalud aplicables, antes de su liberación a producción.
Alcance	Módulos de autenticación (SSO), historia clínica electrónica, telemedicina, pagos y facturación (integración AS/400); evidencia de los últimos 2 meses.
Criterios de auditoría	ISO/IEC 25010; Ley 1581 de 2012 y Decreto 1377 de 2013; Resolución 1995 de 1999; Resoluciones 2654 y 3100 de 2019; PCI-DSS.
Equipo auditor	Auditor líder (externo, independiente del equipo Scrum) + oficial de protección de datos + especialista en seguridad de la información.
Fecha de ejecución	Dentro de las 3 semanas previas a la liberación contractual, idealmente en la primera semana para permitir remediación.
Evidencias a recolectar	Bitácora de incidencias (INC-101 a INC-107), control de cambios (CR-201 a CR-205), resultados de pruebas, registros de acceso a HCE, configuración del canal de video, logs de pagos.

HALLAZGOS DE AUDITORIA - PARTE 1

Solucion de la seccion 5.2 del archivo de apoyo (hallazgos 1 a 3)

N°	Hallazgo	Criterio incumplido	Evidencia	Sev.	Recomendación
1	Control de acceso roto permite lectura de HCE de pacientes no asignados (IDOR).	Res. 1995/1999; ISO 25010 – Seguridad (confidencialidad)	INC-101	Alta	Validar autorización a nivel de objeto en el backend; no confiar en el ID recibido del cliente.
2	Cuentas administrativas compartidas, sin expiración de contraseña.	Gestión de identidad; ISO 25010 – Seguridad (responsabilidad)	INC-102	Alta	Eliminar cuentas compartidas; asignar cuentas nominales con MFA y expiración.
3	Canal de videoconsulta transmitido sin cifrar por error de despliegue.	Res. 2654/2019; RF-060	INC-103 / CR-202	Alta	Forzar TLS/SRTP en producción; bloquear despliegues sin aprobación registrada.

HALLAZGOS DE AUDITORIA - PARTE 2 Y CONCLUSION



Hallazgos 4 y 5, y conclusion general de la auditoria (seccion 5.3)

N°	Hallazgo	Criterio incumplido	Evidencia	Sev.	Recomendación
4	Registros de la pasarela de pagos exponen el número completo de tarjeta.	PCI-DSS (enmascaramiento del PAN)	INC-104	Alta	Enmascarar o tokenizar el PAN en todos los logs; revisar configuración con PayGateCol.
5	No se registran los accesos de lectura a la historia clínica.	RF-045; Res. 1995/1999 (trazabilidad)	INC-105	Media-alta	Extender el log de auditoría inmutable a operaciones de lectura, con revisión periódica.

Conclusión general de la auditoría

MediCitas v3.2 no está listo para liberarse en su estado actual: persisten brechas de seguridad y trazabilidad no remediadas, pruebas críticas de seguridad y desempeño sin ejecutar, y cambios desplegados sin control (CR-202, CR-205). Se recomienda no liberar telemedicina ni pagos hasta remediar los hallazgos de severidad alta.

APLICACION DE ISO/IEC 25010 AL CASO



Cada hallazgo se justifica con la característica de calidad que compromete

Hallazgo	Característica ISO/IEC 25010	Justificación
1. Control de acceso roto (IDOR)	Seguridad — Confidencialidad	El sistema no impide que un usuario acceda a datos que no le corresponden.
2. Cuentas administrativas compartidas	Seguridad — Responsabilidad / autenticidad	No es posible atribuir una acción a una identidad única.
3. Canal de video sin cifrar	Seguridad — Confidencialidad e integridad	Los datos de salud viajan expuestos y pueden ser interceptados o alterados.
4. Logs de pago sin enmascarar	Seguridad — Confidencialidad	Se expone información financiera sensible en registros internos.
5. Falta de log de lectura en HCE / batch sin alertas	Fiabilidad — Madurez / tolerancia a fallos	El sistema no detecta ni notifica condiciones anómalas de operación.

Las pruebas de seguridad y de carga no ejecutadas (pentesting, telemedicina) también comprometen la Capacidad de prueba, subcaracterística de Mantenibilidad en ISO/IEC 25010.

METRICAS DE CALIDAD PARA EL CASO



Cinco metricas calculadas con los datos del propio escenario

Métrica	Cálculo con los datos del caso	Criterio de aceptación
Densidad de hallazgos críticos	5 hallazgos de severidad alta / 8 funcionalidades críticas = 0.63	0 hallazgos de severidad alta abiertos antes del release
Cobertura de pruebas críticas ejecutadas	2 de 4 pruebas críticas ejecutadas (pentesting HCE y carga de telemedicina no ejecutadas) = 50%	≥ 100% de pruebas críticas ejecutadas antes del release
Tasa de cambios desplegados sin revisión	2 de 5 cambios (CR-202, CR-205) sin revisión registrada = 40%	0% de cambios desplegados sin aprobación
Fallos del batch sin alerta	3 fallos en 4 semanas sin generar alerta automática	100% de los fallos deben generar alerta (0 fallos silenciosos)
Disponibilidad en horario de atención	Criterio contractual 99.5% (7 a.m.–9 p.m.); sin medición formal reportada en el escenario	≥ 99.5% medido con monitoreo continuo

CONCLUSIONES Y RECOMENDACIONES PRIORIZADAS

Síntesis del reporte de solución de problemas de la semana 2

CRÍTICO

Corregir el control de acceso a la HCE (IDOR) y extender el log de auditoría a las lecturas.

CRÍTICO

Forzar el cifrado del canal de videoconsulta y enmascarar el PAN en los logs de pagos; re-ejecutar pruebas de seguridad.

ALTO

Eliminar las cuentas administrativas compartidas y aplicar MFA con expiración de contraseñas.

ALTO

Ejecutar el pentesting de HCE y la prueba de carga de agendamiento/telemedicina antes de congelar el release.

MEDIO

Formalizar el control de cambios e implementar alertas automáticas para el batch de facturación.

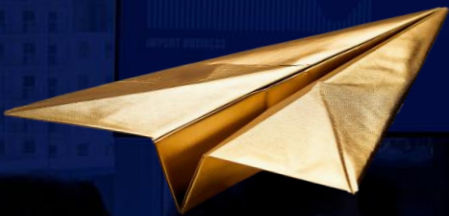
Dado el número y severidad de los hallazgos abiertos, se recomienda solicitar una prórroga de la fecha contractual o liberar por fases, excluyendo telemedicina y pagos hasta remediar los hallazgos críticos.



UNIMINUTO

Corporación Universitaria Minuto de Dios
Educación de calidad al alcance de todos

Rectoría UNIMINUTO Virtual



GRACIAS

Educamos sin fronteras transformándonos para el futuro con

CALIDAD Y CALIDEZ

www.uniminuto.edu/uniminuto-virtual

